HackTheBox – The Suspicious Domain (Very Easy | OSINT)

Tác giả: Huỳnh Thanh Giảng

Ngày viết: 01/04/2026

Điểm: 20 points

Độ khó: Very Easy (User-Rated Difficulty: Low)

1. Giới thiệu

Đây là một challenge dạng **Interactive Q&A Platform** sử dụng giao diện web giả lập tên **DomainScope** – một nền tảng phân tích domain chuyên nghiệp. Thay vì submit flag trực tiếp, người chơi phải trả lời **6 câu hỏi Investigation Challenge** và **3 câu Correlation Challenge** để unlock flag cuối cùng.

Challenge này tập trung vào kỹ năng đọc và phân tích thông tin từ các nguồn OSINT cơ bản về một domain (WHOIS, DNS, Hosting, Threat Intelligence…).

2. Challenge Scenario

Challenge Scenario

Following the discovery of the suspicious social media profile "TechReviewer2024", investigators have uncovered a review manipulation campaign targeting TechFlow. The domain "alexmorgan-reviews.net" appears to be central to this operation. Use DomainScope to investigate this domain and identify the key identifier linking it to the broader campaign infrastructure.

:: Challenge Type :: Interactive Q&A Platform (6 questions + 3 correlation questions).

:: How to Play :: (1) Click "Start Instance" and wait for the Docker container to spawn | (2) Open the given URL in your browser - this will take you to "DomainScope" | (3) The domain "alexmorgan-reviews.net" will be pre-loaded | (4) Explore the different tabs (WHOIS, DNS Records, Hosting, etc.) to gather intelligence | (5) Go to the "Investigation Challenge" tab (rightmost tab) | (6) Answer 6 questions about the domain | (7) Once you've answered all 6, you'll unlock the "Correlation Challenge" | (8) Finish the 3 extra correlation questions - the final flag will then show up on the page.

Sau khi phát hiện profile mạng xã hội đáng ngờ mang tên **"TechReviewer2024"**, các nhà điều tra đã phát hiện ra một **chiến dịch thao túng đánh giá (review manipulation campaign)** đang nhắm vào công ty **TechFlow**.

Domain **alexamorgan-reviews.net** được xác định là trung tâm của toàn bộ chiến dịch này. Nhiệm vụ của chúng ta là sử dụng **DomainScope** để điều tra domain, thu thập intelligence từ các tab khác nhau và xác định các **key identifier** liên kết domain này với hạ tầng lớn hơn của chiến dịch.

3. Methodology (Cách tiếp cận)

- Không sử dụng bất kỳ tool OSINT bên ngoài nào (Google Dorks, theHarvester, Maltego…).
- Toàn bộ thông tin cần thiết đều nằm sẵn trong giao diện **DomainScope** sau khi start instance.
- Quy trình: Đọc kỹ scenario → Khám phá lần lượt các tab → Trả lời 6 câu hỏi Investigation → Unlock và giải 3 câu Correlation.

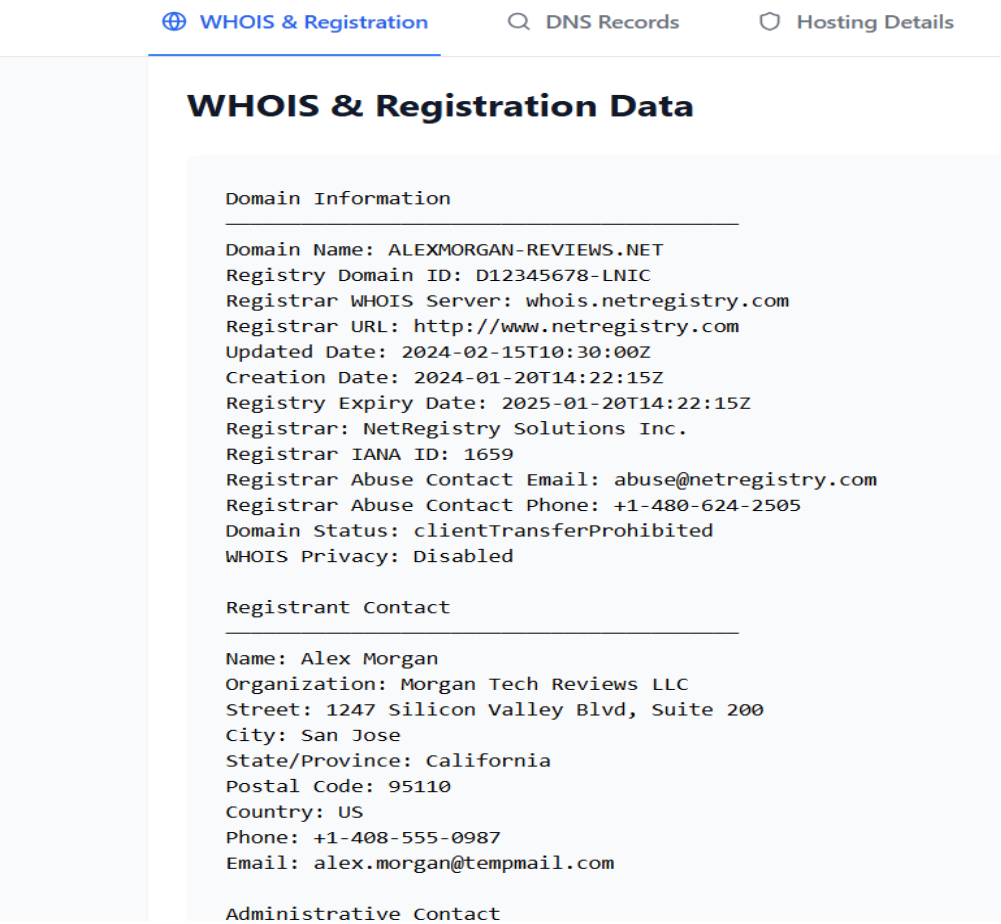
4. Enumeration & Investigation

4.1. Tab WHOIS & Registration

Đây là tab đầu tiên và quan trọng nhất. Tab này cung cấp thông tin đăng ký domain (WHOIS record) khá đầy đủ vì **WHOIS Privacy: Disabled**.

Các thông tin nổi bật:

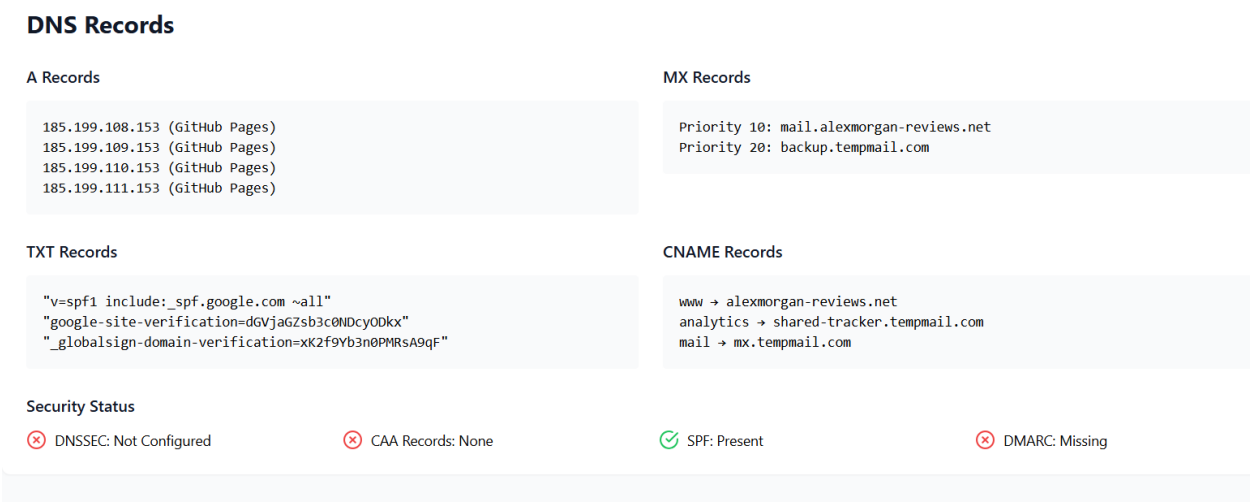
- **Domain Name**: ALEXMORGAN-REVIEWS.NET
- **Registrant Name**: **Alex Morgan**
- **Organization**: **Morgan Tech Reviews LLC**
- **Address**: 1247 Silicon Valley Blvd, Suite 200, San Jose
- **Registrar**: NetRegistry Solutions Inc.
- **Creation Date**: 2024-01-20
- **Updated Date**: 2024-02-15
- **Expiry Date**: 2025-01-20



4.2. Tab DNS Records

Tab DNS Records cho thấy domain đang được cấu hình khá đặc biệt:

- **A Records**: Domain trỏ đến nhiều IP trong dải **185.199.108.153 ~ 185.199.111.153**, tất cả đều thuộc **GitHub Pages**.
- **MX Records**:
  - Priority 10: mail.alexmorgan-reviews.net
  - Priority 20: backup.tempmail.com → Cho thấy threat actor đang sử dụng **temp mail** (tạm thời) làm email server.
- **CNAME Records**:
  - analytics → shared-tracker.tempmail.com
  - mail → mx.tempmail.com
- **TXT Records**: Có SPF record trỏ về Google và một số verification token (Google Site Verification, GlobalSign).
- **Security Status**: SPF Present, nhưng thiếu DMARC và DNSSEC.



Thông tin từ tab này giúp trả lời các câu hỏi liên quan đến email service và hosting platform mà threat actor đang sử dụng.

4.3. Tab Hosting & Infrastructure Details

Tab này xác nhận rõ ràng về hạ tầng:

- **Primary IP**: 185.199.108.153
- **ASN**: AS36459 (GitHub, Inc.)
- **Network**: GitHub Pages CDN
- **Location**: San Francisco, California, US
- **ISP**: GitHub, Inc.
- **SSL Certificate**: Issued by Let’s Encrypt (valid từ 2024-02-15 đến 2024-05-15)

- **Digital Fingerprints** (rất quan trọng):
  - **Google Analytics ID**: G-TECHFLOW4472891
  - **Google Tag Manager**: GTM-MRGN2024
  - **Facebook Pixel ID**: 887755443322110
  - **HTML Meta Generator**: WordPress 6.4.2

Hosting & Infrastructure Details

Infrastructure

Primary IP: 185.199.108.153
ASN: AS36459 (GitHub, Inc.)
Network: GitHub Pages CDN
Location: San Francisco, California, US
ISP: GitHub, Inc.
Reverse DNS: cdn-185-199-108-153.github.com

SSL Certificate

Issuer: Let's Encrypt Authority X3
Serial: 04:7d:9f:c4:7a:2e:89:5b:33:15:87:9a:3f:2d:ef:12
Valid From: 2024-02-15 00:00:00 UTC
Valid Until: 2024-05-15 23:59:59 UTC
Algorithm: SHA256-RSA
Status: Valid

Digital Fingerprints

Favicon Hash (MMH3): -1028699455
Google Analytics ID: G-TECHFLOW4472891
Google Tag Manager: GTM-MRGN2024
Facebook Pixel ID: 887755443322110
HTML Meta Generator: WordPress 6.4.2

4.4. Tab Historical Data & Timeline

Tab này cho thấy timeline hoạt động của domain:

- **Registered**: 2024-01-20
- **First DNS Resolution**: 2024-01-20
- **WHOIS Contact Updated**: 2024-02-15
- **SSL Certificate Issued**: 2024-02-15
- **Website First Detected**: 2024-03-01
- **Analytics Tags Added**: 2024-03-05

Historical Data & Timeline

Registration Timeline

2024-01-20 14:22:15 — Domain Registered (NetRegistry)
2024-01-20 16:45:00 — First DNS Resolution
2024-02-15 10:30:00 — WHOIS Contact Updated
2024-02-15 12:00:00 — SSL Certificate Issued
2024-03-01 09:15:00 — Website First Detected
2024-03-05 11:20:00 — Analytics Tags Added

Archive Data

Wayback Machine: 3 snapshots (First: 2024-03-05, Last: 2024-03-15)
Archive.today: 1 snapshot (2024-03-10)
Google Cache: 2024-03-14 07:23:45 UTC

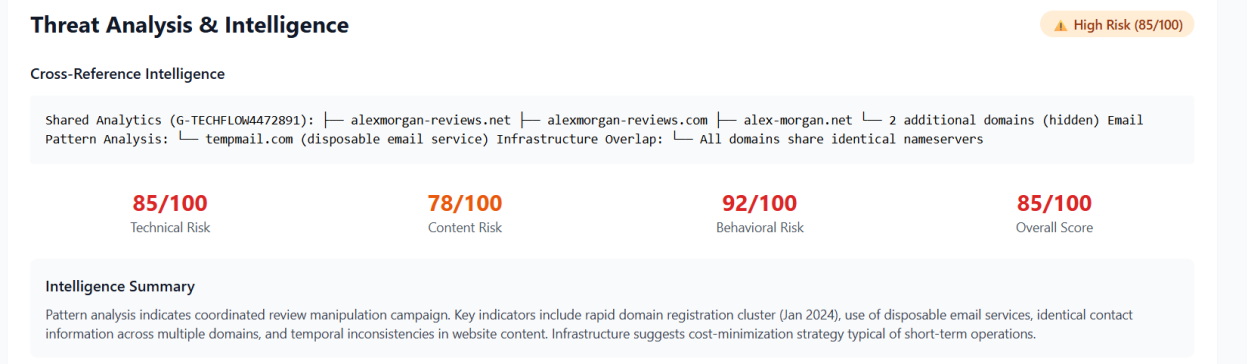
Passive DNS

First Seen: 2024-01-20
Last Seen: 2024-03-15
Total Queries: 1,247
Unique Resolvers: 89

4.5. Tab Threat Analysis

Tab này đánh giá domain ở mức **High Risk (85/100)** và cung cấp cái nhìn tổng hợp về chiến dịch:

- **Cross-Reference Intelligence**:
  - Shared Google Analytics ID **G-TECHFLOW4472891** liên kết với nhiều domain khác: alexmorgan-reviews.net, alexmorgan-reviews.com, alex-morgan.net và 2 domain ẩn khác.
  - Email pattern sử dụng **tempmail.com** (disposable email service).
  - Tất cả các domain đều chia sẻ cùng nameservers.
- **Risk Scores**:
  - Technical Risk: 85/100
  - Behavioral Risk: 92/100 (cao nhất)
  - Overall Score: 85/100
- **Intelligence Summary**: Pattern analysis chỉ ra đây là một **coordinated review manipulation campaign**. Các dấu hiệu chính bao gồm: đăng ký domain hàng loạt vào tháng 1/2024, sử dụng disposable email, thông tin liên hệ giống nhau trên nhiều domain, và chiến lược hạ tầng chi phí thấp (cost-minimization).



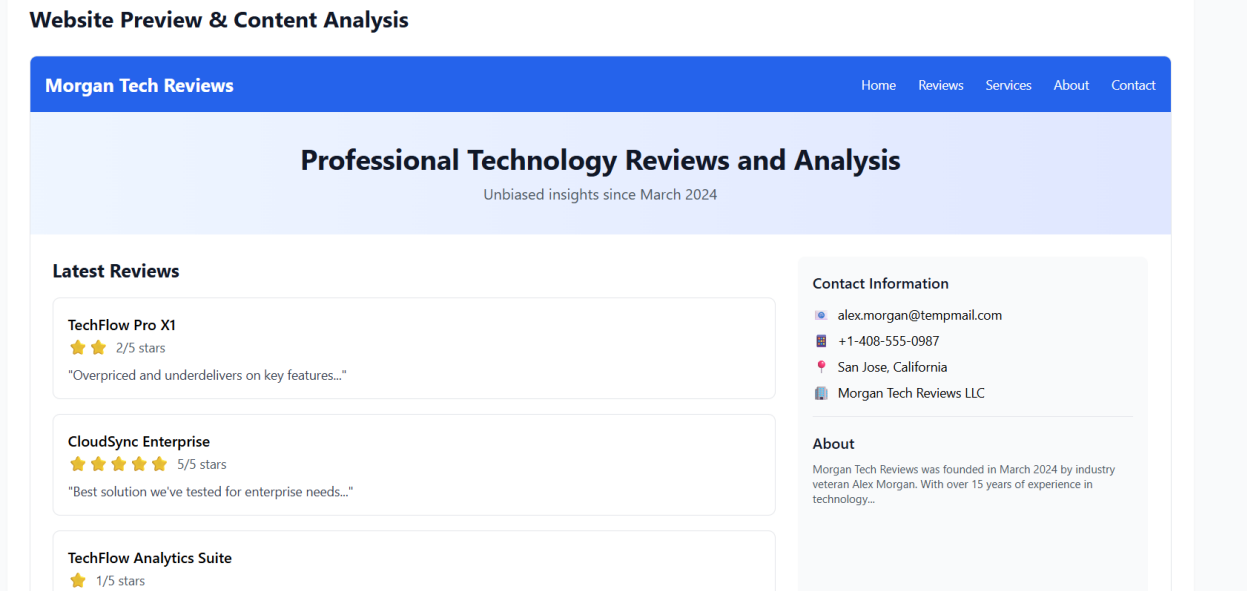
4.6. Tab Website Preview

Website của domain **alexamorgan-reviews.net** mang tên **Morgan Tech Reviews**, tự giới thiệu là trang đánh giá công nghệ "unbiased" từ tháng 3/2024.

Nội dung nổi bật:

- Có review tiêu cực về sản phẩm **TechFlow Pro X1** (2/5 sao) và **TechFlow Analytics Suite** (1/5 sao).
- Có review tích cực về **CloudSync Enterprise** (5/5 sao) — cho thấy chiến dịch đang cố gắng bôi nhọ TechFlow trong khi nâng điểm đối thủ.
- Contact Information:
  - Email: **alex.morgan@tempmail.com**
  - Phone: +1-408-555-0987
  - Address: San Jose, California

- Company: Morgan Tech Reviews LLC

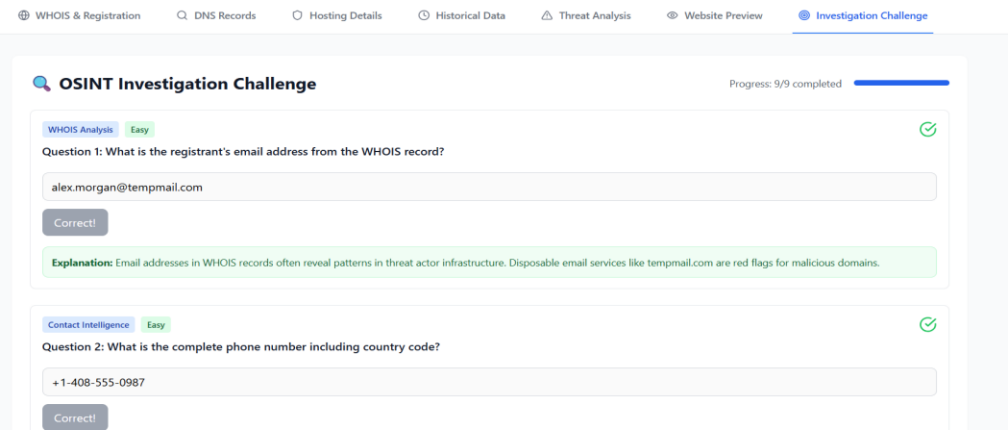


4.7. OSINT Investigation Challenge

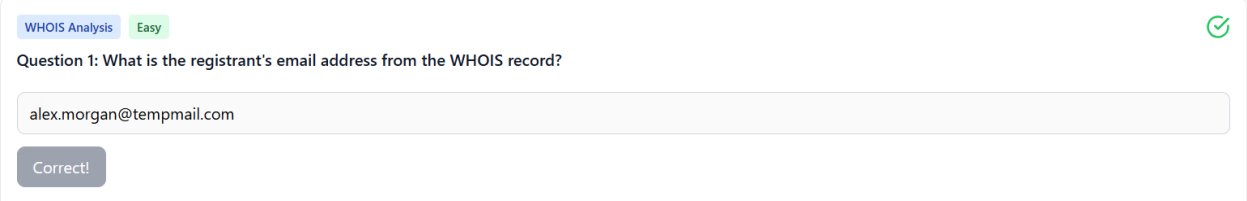
Sau khi khám phá đầy đủ các tab trong DomainScope, tôi chuyển sang tab **Investigation Challenge** (tab bên phải cùng) để trả lời 6 câu hỏi. Các câu hỏi được thiết kế để kiểm tra khả năng trích xuất thông tin chính xác từ từng tab.

Các câu hỏi chủ yếu tập trung vào:

- Thông tin từ **WHOIS & Registration**
- Thông tin liên hệ (email, phone) từ website và WHOIS
- Hạ tầng kỹ thuật (hosting, email service)
- Mục tiêu của chiến dịch

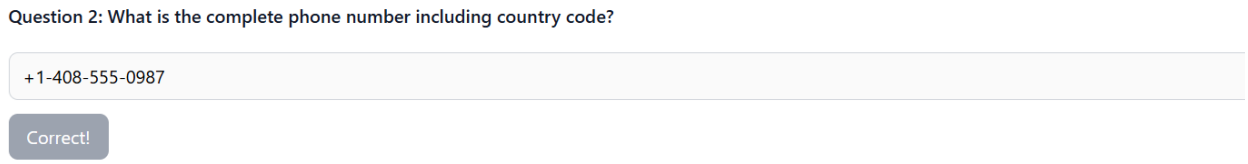


Question 1: What is the registrant's email address from the WHOIS record?



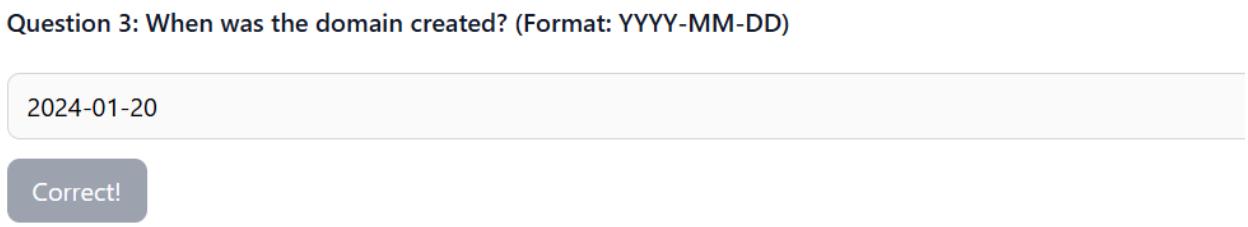
→ Thông tin được lấy trực tiếp từ tab WHOIS & Registration.

Question 2: What is the complete phone number including country code?



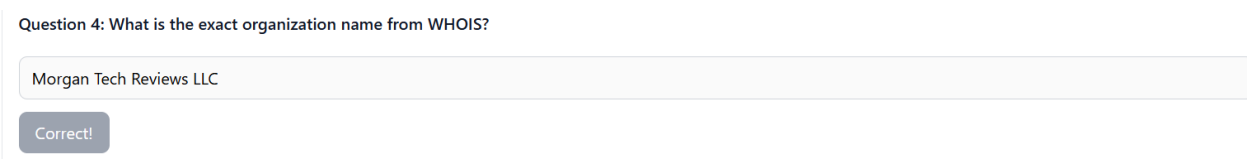
→ Thông tin lấy từ phần Contact Information trong tab Website Preview.

Question 3: When was the domain created? (Format: YYYY-MM-DD)



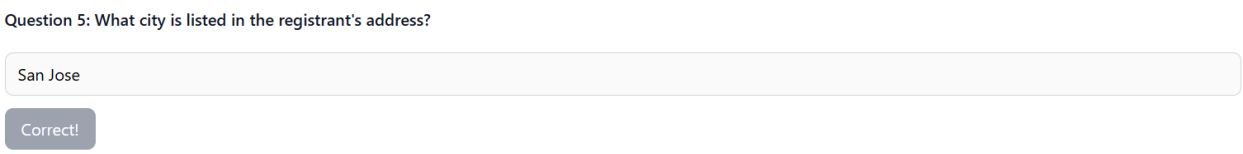
→ Lấy trực tiếp từ trường Creation Date trong tab WHOIS & Registration.

Question 4: What is the exact organization name from WHOIS?



→ Lấy từ tab WHOIS & Registration.

Question 5: What city is listed in the registrant's address?



→ Lấy từ trường City trong phần Registrant Contact của tab WHOIS & Registration.

Question 6: What is the domain's transfer status?

Question 6: What is the domain's transfer status?

clientTransferProhibited

Correct!

→ Lấy từ tab WHOIS & Registration (Domain Status).

Trạng thái này thường được threat actor sử dụng để ngăn chặn việc chuyển nhượng domain trái phép.

5. Correlation Challenge

Question 7: What company is being targeted?

Question 7: What company is being targeted?

Tech Flow

Correct!

→ Lấy từ Challenge Scenario + xác nhận qua Google Analytics ID G-TECHFLOW... và các review tiêu cực về sản phẩm TechFlow trên website.

Question 8: What email service is the threat actor using?

Question 8: What email service is the threat actor using?

tempmail

Correct!

→ Dựa vào MX Records, CNAME Records và email registrant (@tempmail.com).

Question 9: How many GitHub Pages IPs are configured?

Question 9: How many GitHub Pages IPs are configured?

4

Correct!

→ Lấy từ tab DNS Records (4 A Records khác nhau thuộc GitHub Pages).

Flag

Congratulations!

You've answered all questions correctly!

Your final flag is:

```
HTB{alexmorgantempmailcom_20240120_morgantechreviewsllc}
```